

GUIA DE COMUNICAÇÃO DE CRISE

Quem comunica, o quê, a quem e quando — em caso de incidente cibernético significativo

Princípio fundamental: Durante um incidente, a comunicação ERRADA pode causar mais dano do que o próprio ataque. A regra de ouro: **transparência com as autoridades, cautela com o público**. Uma única pessoa faz porta-voz externo. Toda a equipa sabe o que pode e não pode dizer.

MATRIZ DE COMUNICAÇÃO — QUEM DIGA O QUÊ A QUEM E QUANDO				
Audiência	Quem comunica	O que dizer (mensagem aprovada)	O que NÃO dizer	Timing / Prazo
COMUNICAÇÕES OBRIGATÓRIAS POR LEI				
■ ■ CNCS / CERT.PT	CISO	Notificação nos prazos legais (24h/72h/1 mês). Total transparência — incluindo detalhes técnicos sensíveis.	Nada a evitar — total abertura. O CNCS tem obrigação de confidencialidade.	24h: aviso 72h: detalhe 1 mês: relatório final
■ ■ CNPD (se dados pessoais)	CISO + DPO	Notificação de violação de dados: natureza, categorias de dados, nº de titulares, medidas tomadas.	Não minimizar o impacto. Não omitir categorias de dados afectados.	72h após conhecimento da violação
■ PJ Cybercrime (se crime)	CISO + Jurídico	Participação criminal com todos os dados disponíveis: IoCs, logs, evidências. Entregar imagens forenses.	Não eliminar evidências antes de contactar a PJ.	Logo que possível após confirmar crime informático
COMUNICAÇÃO INTERNA				
■ Colaboradores (toda a empresa)	CEO / CISO	O que aconteceu (brevemente), que sistemas estão afectados, o que devem fazer/não fazer, quando terão mais informação.	Não dizer 'ataque' ou 'ransomware' em canais não seguros. Não pedir silêncio total — gera rumores.	Dentro de 2-4h após contenção inicial
■ Equipa de Resposta	CISO / Comandante IC	Briefing técnico completo. Responsabilidades de cada membro. Canais de comunicação alternativos.	Nada a omitir — equipa precisa de toda a informação.	Imediatamente após activação do IRP
COMUNICAÇÃO EXTERNA (CAUTELA MÁXIMA)				
■ Clientes Afectados	CEO / Comunicação	'Detectámos um incidente que pode ter afectado os seus dados. Estamos a investigar. Tomaremos medidas de X e Y. Contacte-nos em [contacto] para dúvidas.'	Não especular sobre causa ou responsabilidade. Não prometer prazos irrealistas. Não minimizar.	RGPD: 'sem demora injustificada' se risco elevado para titulares
■ Parceiros / Fornecedores Afectados	CISO / CEO	Notificar se os seus dados ou serviços foram potencialmente afectados. Dar orientações de precaução.	Não partilhar IoCs sensíveis antes de validar com CNCS.	Logo após confirmar impacto na cadeia de abastecimento

Audiência	Quem comunica	O que dizer (mensagem aprovada)	O que NÃO dizer	Timing / Prazo
■ Media / Imprensa	CEO / Comunicação (1 porta-voz)	'Estamos conscientes do incidente e estamos a trabalhar activamente para o resolver com o apoio das autoridades competentes. Forneceremos actualizações quando tivermos mais informação.'	<i>Não detalhar tecnicamente o ataque. Não culpar fornecedores sem investigação completa. Não confirmar dados roubados antes de confirmar com autoridades.</i>	Só se incidente se torna público. Não comunicar proactivamente à media.
■ Redes Sociais	CEO / Comunicação	Se necessário: mensagem breve e controlada. Remeter para comunicado oficial.	<i>Nunca comentar detalhes técnicos. Nunca responder a provocações online.</i>	Só se incidente já for público e houver pressão para responder

■ AS 5 COISAS QUE NUNCA DIZER DURANTE UM INCIDENTE

1. 'Não temos dados dos vossos' — antes de investigar completamente · 2. 'Foi culpa do [nome do fornecedor]' — antes da investigação · 3. 'Está tudo controlado' — se não tiver a certeza · 4. 'O ataque entrou por [detalhe técnico]' — antes de fechar a vulnerabilidade · 5. 'Não vamos pagar' — antes de consultar PJ e seguradora